Perigen - Cyber Security Threat Assessment

Report Date: March 20, 2019 15:53
Data Range: 2019-01-01 00:00 2019-01-31 00:00 EST (FAZ local)

Table of Contents

Organizational File Usage 3
Files Needing Inspection 3
Breakdown of File Types 3
Results of Executable Sandbox Analysis 4
Top Sandbox-identified Malicious EXEs 4
Top Sources of Sandbox Discovered Malware 4
Recommended Actions 5
Security and Threat Prevention 6
- High Risk Applications 6
- High Risk Applications 6
- Application Vulnerability Exploits 6
- Top Application Vulnerability Exploits Detected 6
- Malware, Botnets and Spyware/Adware 7
- Top Malware, Botnets and Spyware/Adware Detected 7
- At-Risk Devices and Hosts 7
- Most At-Risk Devices and Hosts 7
- Encrypted Web Traffic 8
- HTTPS vs. HTTP Traffic Ratio 8
- Top Source Countries 8
- Top Source Countries 8

User Productivity 9
- Application Usage 9
- App Categories 9
- Cloud Usage (SaaS) 9
- Cloud Usage (IaaS) 9
- Application Category Breakdowns 10
- Remote Access Applications 10
- Proxy Applications 10
- Top Social Media Applications 10
- Top Video/Audio Streaming Applications 10
- Top Gaming Applications 10
- Top Peer to Peer Applications 10
- Web Usage 11
- Top Web Categories 11
- Top Web Applications 11
- Websites Frequented 12
- Most Visited Web Domains 12
- Top Websites by Browsing Time 12

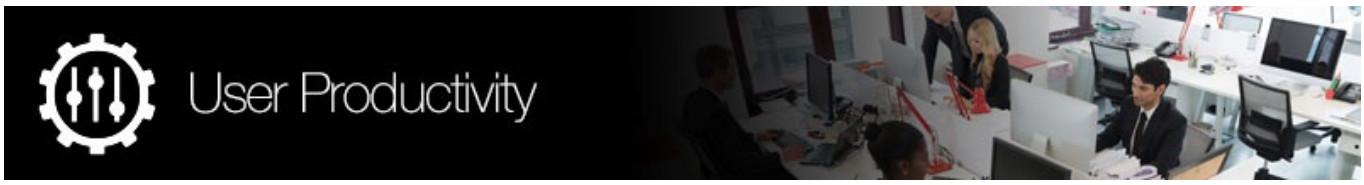
Network Utilization 13
- Bandwidth 13
- Average Bandwidth by Hour 13
- Top Bandwidth Consuming Sources/Destinations 13

FortiGuard Security and Services 14
Appendix A 15
- Devices 15

Executive Summary

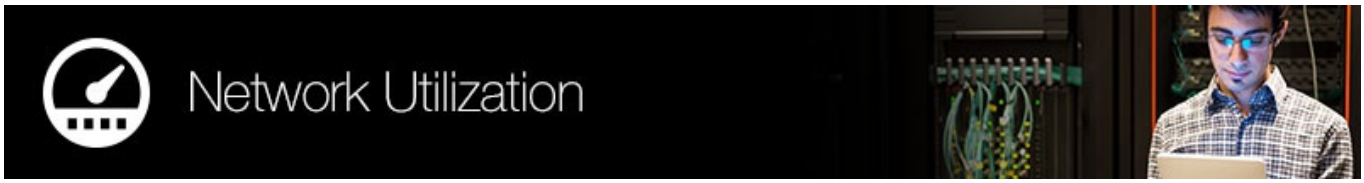
IPS Attacks Detected: 4
Malware/Botnets Detected: 0
High-Risk Applications Used: 11
Malicious Websites Detected: 23

Last year, over 2,100 enterprises were breached as a result of poor internal security practices and latent vendor content security. The average cost of a corporate security breach is estimated at $3.5 million USD and is rising at 15% year over year. Intrusions, malware/botnets and malicious applications collectively comprise a massive risk to your enterprise network. These attack mechanisms can give attackers access to your most sensitive files and database information. FortiGuard Labs mitigates these risks by providing award-winning content security and is consistently rated among industry leaders by objective third parties such as NSS Labs, VB 100 and AV Comparatives.



Applications Detected: 316
Top Used Application: HTTPS.BROWSER
Top Application Category: Web.Client
Websites Visited: 63
Top Website: servicemap.spccint.com
Top Web Category: Malicious Websites

User application usage and browsing habits can not only be indicative of inefficient use of corporate resources, but can also indicate a lack of proper enforcement of corporate usage policies. Most enterprises recognize that personal use of corporate resources is acceptable. But there are many grey areas that businesses must keep a close eye on including: use of proxy avoidance/peer to peer applications, inappropriate web browsing, phishing websites, and potentially illegal activity - all of which expose your company to undue liability and potential damages. With over 5,800 application control rules and 250 million categorized websites, FortiGuard Labs provides telemetry that FortiOS uses to keep your business running effectively.



Total Bandwidth: 1501903508489
Top Host by Bandwidth: 10.108.100.15

Performance effectiveness is an often undervalued aspect of security devices, but firewalls must keep up with the line speeds that today's next generation switches operate at. A recent survey by Infonetics indicates that 77% of decision-makers at large organizations feel that they must upgrade their network security performance (100+ Gbps aggregate throughput) in the coming year. FortiGates leverage FortiASICs to accelerate CPU intensive functions such as packet forwarding and pattern matching. This offloading typically results in a 5-10X performance increase when measured against competitive solutions.

Sandbox Analysis

Today's increasingly sophisticated threats can mask their maliciousness and bypass traditional antimalware security. Conventional antimalware engines are, in the time afforded and to the certainty required, often unable to classify certain payloads as either good or bad; in fact, their intent is unknown. Sandboxing helps solve this problem – it entices unknown files to execute in a protected environment, observes its resultant behavior and classifies its risk based on that behavior. With this functionality enabled for your assessment, we have taken a closer look at files traversing your network.

Organizational File Usage

Total Files Detected (0)

During the assessment period, we monitored the total number of files that were sent across your network. These files could have been email attachments, files uploaded to file sharing services, downloads from the Internet, etc. This number will give you an idea of the sheer amount of file-based activity either inbound or outbound.

Subset of Files Which Could be Sent for Sandbox Inspection ( )

While some file types like .png files are extremely low risk in nature, others can be executed or contain macros and other active code that could exhibit malicious behaviors. Common files types such as exe, doc, xls, and zip should be inspected for their potential to deliver threats to your network. Fortinet's sandboxing technologies can inspect more than 50 different file types even while obfuscated within multiple layers of compression.

Files Needing Inspection

No matching log data for this report

Breakdown of File Types

No matching log data for this report

Results of Executable Sandbox Analysis

Total EXE Files Analyzed (0)

As a highest risk file type, we started with executables which, after a standard anti-malware check on the FortiGate, were sent to the sandbox for further inspection. The number here represents the subset of executables that were sent to the sandbox for additional scrutiny.

Total Malicious EXEs Found (0)

Of the Total EXE Files Analyzed, certain files may have tested positive for malicious threat payloads upon further inspection. Often times this subsequent identification is due to later stage downloads or communications that are known to be malicious. This is the number of malicious files that were discovered during our executable analysis.

Top Sandbox-identified Malicious EXEs

No matching log data for this report

Top Sources of Sandbox Discovered Malware

No matching log data for this report

Recommended Actions

Application Vulnerability Attacks Detected (1)

Application vulnerabilities (also known as IPS attacks) act as entry points used to bypass security infrastructure and allow attackers a foothold into your organization. These vulnerabilities are often exploited due to an overlooked update or lack of patch management process. Identification of any unpatched hosts is the key to protecting against application vulnerability attacks.

Malware Detected (0)

Malware can take many forms: viruses, trojans, spyware/adware, etc. Any instances of malware detected moving laterally across the network could also indicate a threat vector originating from inside the organization, albeit unwittingly. Through a combination of signature and behavioral analysis, malware can usually be prevented from executing and exposing your network to malicious activity. Augmenting your network with APT/sandboxing technology (e.g. FortiSandbox) can also prevent previously unknown malware (zero-day threats) from propagating within your network.

Botnet Infections (0)

Bots can be used for launching denial-of-service (DoS) attacks, distributing spam, spyware and adware, propagating malicious code, and harvesting confidential information which can lead to serious financial and legal consequences. Botnet infections need to be taken seriously and immediate action is required. Identify botnet infected computers and clean them up using antivirus software. Fortinet's FortiClient can be used to scan and remove botnets from the infected hosts.

Malicious Websites Detected (23)

Malicious websites are sites known to host software/malware that is designed to covertly collect information, damage the host computer or otherwise manipulate the target machine without the user's consent. Generally visiting a malicious website is a precursor to infection and represents the initial stages of the kill chain. Blocking malicious sites and/or instructing employees not to visit/install software from unknown websites is the best form of prevention here.

Phishing Websites Detected (4)

Similar to malicious websites, phishing websites emulate the webpages of legitimate websites in an effort to collect personal or private (logins, passwords, etc.) information from end users. Phishing websites are often linked to within unsolicited emails sent to your employees. A skeptical approach to emails asking for personal information and hovering over links to determine validity can prevent most phishing attacks.

Proxy Applications Detected (5)

These applications are used (usually intentionally) to bypass in-place security measures. For instance, users may circumvent the firewall by disguising or encrypting external communications. In many cases, this can be considered a willful act and a violation of corporate use policies.

Remote Access Applications Detected (7)

Remote access applications are often used to access internal hosts remotely, thus bypassing NAT or providing a secondary access path (backdoor) to internal hosts. In the worst case scenario, remote access can be used to facilitate data exfiltration and corporate espionage activity. Many times, the use of remote access is unrestricted and internal corporate use changes should be put into practice.

P2P and Filesharing Applications (0)

These applications can be used to bypass existing content controls and lead to unauthorized data transfer and data policy violations. Policies on appropriate use of these applications need to be implemented.

Security and Threat Prevention

High Risk Applications

The FortiGuard research team assigns a risk rating of 1 to 5 to an application based on the application behavioral characteristics. The risk rating can help administrators to identify the high risk applications quickly and make a better decision on the application control policy. Applications listed below were assigned a risk rating of 4 or higher.

High Risk Applications

Risk	Application Name	Category	Technology	User	Bandwidth	Session
5	Hotspot.Shield	Proxy	Client-Server	2	71.41 KB	9
5	Psiphon	Proxy	Client-Server	3	6.65 MB	5
5	Proxy.HTTP	Proxy	Network-Protocol	3	37.22 KB	5
5	Yoga.VPN	Proxy	Client-Server	2	253.51 KB	2
4	Solarwinds.Take.Control	Remote.Access	Client-Server	6	60.31 MB	8,906
4	Citrix.Receiver	Remote.Access	Client-Server	3	1.33 MB	2,633
4	TeamViewer	Remote.Access	Client-Server	12	37.22 MB	476
4	RDP	Remote.Access	Client-Server	19	33.71 MB	255
4	LogMeIn	Remote.Access	Client-Server	4	10.99 MB	75
4	TeamViewer_CallRequest	Remote.Access	Client-Server	2	156.17 MB	7
4	Bomgar	Remote.Access	Client-Server	1	7.01 KB	1
4	TeamViewer_CallReceive	Remote.Access	Client-Server	1	374.26 KB	1

Figure 1: Highest risk applications sorted by risk and sessions

Application Vulnerability Exploits

Application vulnerabilities can be exploited to compromise the security of your network. The FortiGuard research team analyzes these vulnerabilities and then develops signatures to detect them. FortiGuard currently leverages a database of more than 5,800 known application threats to detect attacks that evade traditional firewall systems. For more information on application vulnerabilities, please refer to FortiGuard at: http://www.fortiguard.com/intrusion.

Top Application Vulnerability Exploits Detected

Severity	Threat Name	Type	CVE-ID	Victim	Source	Count
5	udp_flood	Anomaly		1	4	4

Figure 2: Top vulnerabilities identified, sorted by severity and count

Malware, Botnets and Spyware/Adware

There are numerous channels that cybercriminals use to distribute malware. Most common methods motivate users to open an infected file in an email attachment, download an infected file, or click on a link leading to a malicious site. During the security assessment, Fortinet identified a number of malware and botnet-related events which indicate malicious file downloads or connections to botnet command and control sites.

Top Malware, Botnets and Spyware/Adware Detected

No matching log data for this report

Figure 3: Common Malware, Botnets, Spyware and Adware detected

At-Risk Devices and Hosts

Based on the types of activity exhibited by an individual host, we can approximate the trustworthiness of each individual client. This client reputation is based on key factors such as websites browsed, applications used and inbound/outbound destinations utilized. Ultimately, we can create an overall threat score by looking at the aggregated activity used by each individual host.

Most At-Risk Devices and Hosts

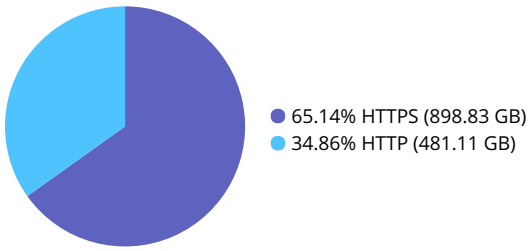
Device	Scores
10.108.114.1	3,869,885
PERLAP2575	917,845
10.108.114.2	377,110
PERLAP2578	340,935
10.108.114.3	272,325
10.108.114.4	113,410
10.108.114.5	63,955
10.108.100.15	44,575
10.108.100.148	26,960
10.108.114.6	10,105

Figure 4: These devices should be audited for malware and intrusion susceptibility

Encrypted Web Traffic

From a security perspective, it's important to visualize how much of your web-based traffic is encrypted. Encrypted traffic poses very real challenges for enterprises who want to ensure that those same applications are not being used for malicious purposes, including data exfiltration. Ideally, your firewall can inspect encrypted traffic at high speeds - this is why performance and hardware/ASIC offloading are key when evaluating a firewall.

HTTPS vs. HTTP Traffic Ratio



Top Source Countries

By looking at IP source traffic, we can determine the originating country of any particular request. Certain botnets, command and control functions, and even remote access can be session heavy and indicative of targeted attacks or persistent threats from nation-states. This chart is representative of country-based traffic - activity from specific originating nations may be anomalous and warrant further investigation.

Top Source Countries

No matching log data for this report

Figure 5: Activity originating from these countries should be audited for expected traffic sources

User Productivity

Application Usage

The FortiGuard research team categorizes applications into different categories based on the application behavioral characteristics, underlying technology, and the related traffic transaction characteristics. The categories allow for better application control. FortiGuard maintains thousands of application sensors and can even perform deep application inspection. For example, IT managers can get unprecedented visibility into filenames sent to the cloud or the titles of videos being streamed.

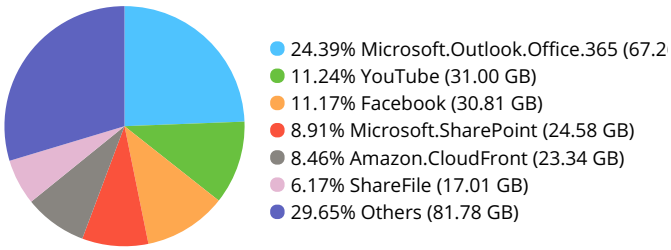
For application category details, see:
http://www.fortiguard.com/encyclopedia/application

App Categories

Web.Client	34.50%
Update	27.19%
Collaboration	9.06%
Video/Audio	8.24%
Email	5.19%
General.Interest	4.15%
Social.Media	4.08%
Storage.Backup	3.03%
Cloud.IT	2.40%
Network.Service	1.43%
Others	0.72%

With the proliferation of cloud-based computing, enterprises are increasingly reliant on third parties for infrastructure plumbing. Unfortunately for enterprises, this means that their information is only as secure as the cloud provider's security. In addition, it can often introduce redundancy (if services are already available internally) and increase costs (if not monitored properly).

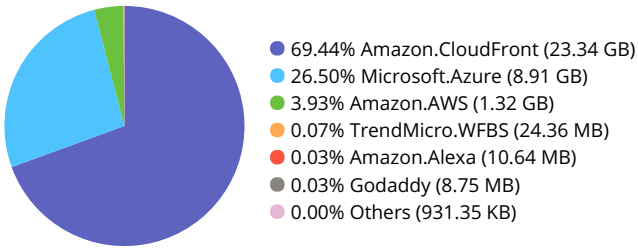
Cloud Usage (SaaS)



IT managers are often unaware of how many cloud-based services are in use within their organization. Sometimes, these applications can be used to circumvent or even replace corporate infrastructure already available to users in lieu of ease of use. Unfortunately, a potential side effect of this is that your sensitive corporate information could be transferred to the cloud. Accordingly, your data could be exposed if the cloud provider's security infrastructure is breached.

The adoption of "infrastructure as a service" (IaaS) platforms is popular and can be very useful when compute resources are limited or have specialized requirements. That said, the effective outsourcing of your infrastructure must be well regulated to prevent misuse. The occasional auditing of IaaS applications can be a useful exercise not only for security purposes, but also to minimize organizational costs associated with pay per use models or recurring subscription fees.

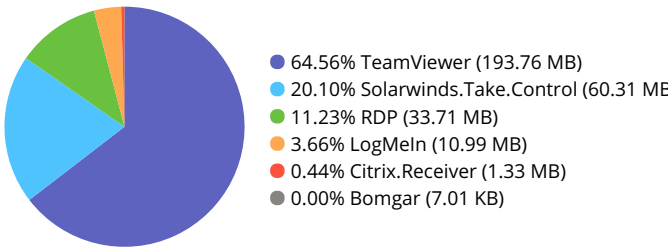
Cloud Usage (IaaS)



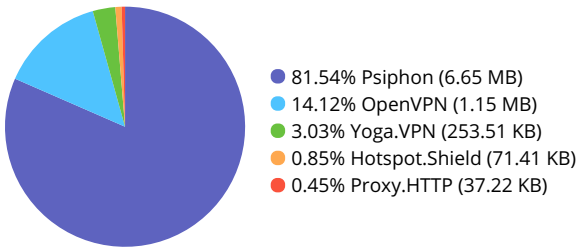
Application Category Breakdowns

Understanding application subcategories can give invaluable insights into how efficiently your corporate network is operating. Certain application types (such as P2P or gaming applications) are not necessarily conducive to corporate environments and can be blocked or limited in their scope. Other applications may have dual purpose uses (such as video/audio streaming or social media apps) and can be managed accordingly. These charts illustrate application categories sorted by the amount of bandwidth they used during the discovery period.

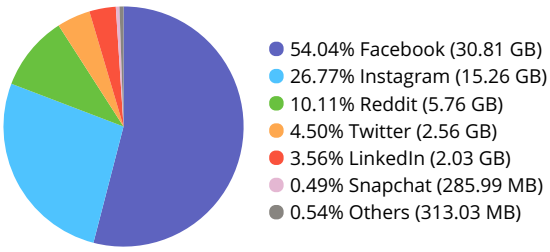
Remote Access Applications



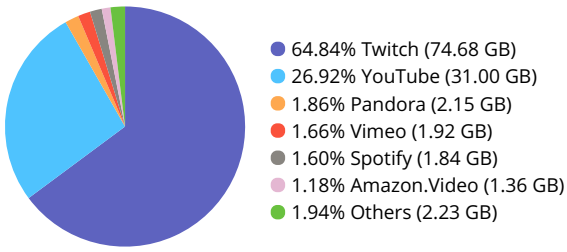
Proxy Applications



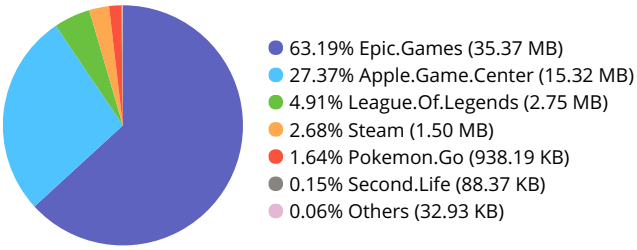
Top Social Media Applications



Top Video/Audio Streaming Applications



Top Gaming Applications



Top Peer to Peer Applications

No matching log data for this report

Web Usage

Web browsing habits can not only be indicative of inefficient use of corporate resources, but can also indicate an inefficient optimization of web filtering policies. It can also give some insight into the general web browsing habits of corporate users and assist in defining corporate compliance guidelines.

Top Web Categories

URL Category	User	Count	Bandwidth
Malicious Websites	19	21,224	136.82 MB
Other Adult Materials	17	155	707.40 KB
Spam URLs	13	74	328.02 KB
Phishing	5	11	51.50 KB
Dynamic DNS	1	5	22.33 KB
Pornography	2	3	13.22 KB

In today's network environments, many applications leverage HTTP for communications – even some you wouldn't normally expect. The primary benefit of HTTP is that communication is ubiquitous, universally accepted and (generally) open on most firewalls. For most business-related and whitelisted applications this typically augments communication, but some non-business applications also use HTTP in either unproductive or potentially nefarious ways.

Top Web Applications

Application	Sessions	Bandwidth
HTTPS.BROWSER	2,393,546	426.43 GB
MS.Windows.Update	42,146	362.20 GB
Twitch	5,758	74.68 GB
Microsoft.Outlook.Office.365	956,312	67.26 GB
HTTP.BROWSER	475,678	55.79 GB
Microsoft.Portal	429,170	36.29 GB
YouTube	16,988	31.00 GB
Facebook	117,512	30.80 GB
Microsoft.SharePoint	72,181	24.55 GB
Amazon.CloudFront	10,779	23.29 GB
Apple.Store	587	21.53 GB
Microsoft.CDN	59,313	19.56 GB
ShareFile	127	17.01 GB
Docker	7,577	16.87 GB
iCloud	25,494	15.96 GB
Instagram	44,798	15.26 GB
Google.Services	222,570	12.75 GB
Microsoft.Office.Update	2,875	10.68 GB
HTTP.Segmented.Download	1,905	8.78 GB
Microsoft.Azure	54	6.22 GB
Reddit	8,105	5.76 GB
Microsoft.Office.Online	173,776	5.24 GB
MS.Windows.Update	240,239	5.09 GB
Google.Ads	77,821	4.43 GB
Google.Accounts	70,288	3.81 GB

Websites Frequented

Websites browsed are strong indicators of how employees utilizing corporate resources and how applications communicate with specific websites. Analyzing domains accessed can lead to changes in corporate infrastructure such as website blocking, deep application inspection of cloud-based apps and implementation of web traffic acceleration technologies.

Most Visited Web Domains

Domain	Category	Visits
servicemap.spccint.com	Malicious Websites	7,027
sp-settings.spccint.com	Malicious Websites	6,026
sp-translation.spccint.com	Malicious Websites	2,892
sp-ip2location.spccint.com	Malicious Websites	1,796
sp-autoupdate.spccint.com	Malicious Websites	1,792
sp-alive-msg.databssint.com	Malicious Websites	1,414
witch.valdikss.org.ru	Malicious Websites	326
api.cogswell.io	Malicious Websites	64
match.bnmla.com	Other Adult Materials	48
*.spccint.com	Malicious Websites	40

Estimated browsing times for individual websites can be useful when trying to get an accurate picture of popular websites. Typically, these represent internal web resources such as intranets, but they can occasionally be indicative of excessive behavior. Browse times can be employed to justify the implementation of web caching technologies or help shape organizational corporate use policies.

Top Websites by Browsing Time

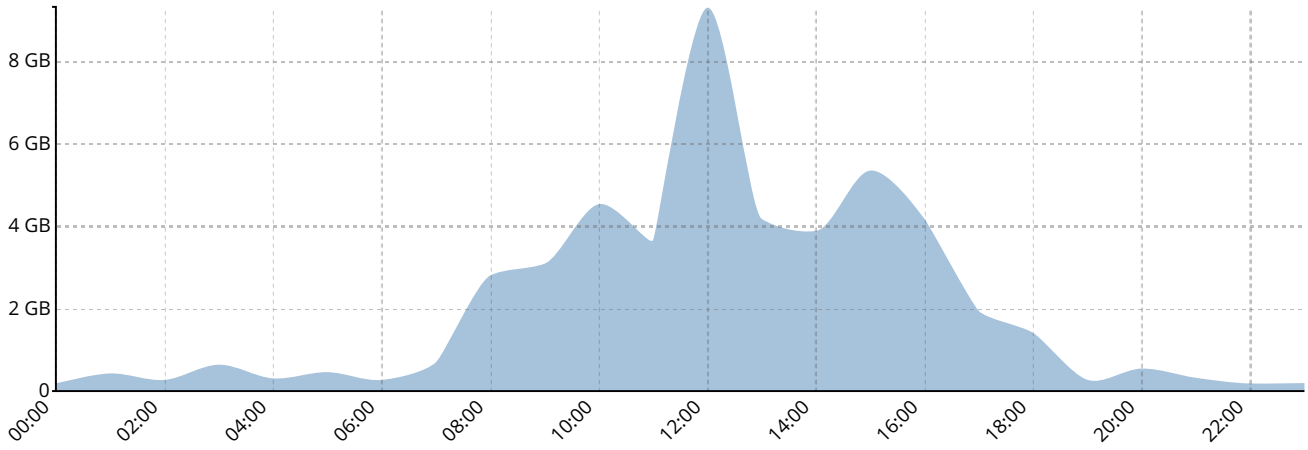
No matching log data for this report

Network Utilization

Bandwidth

By looking at bandwidth usage when distributed over an average day, administrators can better understand their organizational ISP connection and interface speed requirements. Bandwidth can also be optimized on an application basis (using throttling), specific users can be prioritized during peak traffic times, and updates can be rescheduled outside of working hours.

Average Bandwidth by Hour



One of the most telling ways to analyze bandwidth is by looking at destinations and sources generating the most traffic. Common destination sites (e.g. external websites), such as those for OS/firmware updates, can be throttled to allow prioritized, business critical traffic. Internally, high traffic hosts can be optimized through traffic shaping or corporate use policies.

Top Bandwidth Consuming Sources/Destinations

Host Name	Bandwidth
team-tx.thinkorswim.com	892.29 MB
servicemap.spccint.com	50.41 MB
sp-settings.spccint.com	38.10 MB
sp-translation.spccint.com	21.51 MB
tlc.thinkorswim.com	18.49 MB
sp-autoupdate.spccint.com	10.48 MB
sp-ip2location.spccint.com	7.85 MB
sp-alive-msg.databssint.com	6.22 MB
management.azure.com	3.64 MB
outlook.live.com	2.55 MB

FortiGuard Security and Services

Knowledge of the threat landscape combined with the ability to respond quickly at multiple levels is the foundation for providing effective security. Hundreds of researchers at FortiGuard Labs scour the cyber landscape every day to discover emerging threats and develop effective countermeasures to protect organizations around the world. They are the reason FortiGuard is credited with over 250 zero-day and vulnerability discoveries and why Fortinet security solutions score so high in real-world security effectiveness tests at NSS Labs, Virus Bulletin, AV Comparatives, and more.

Next Generation Application Control & IPS

Application control and intrusion prevention (IPS) are foundational security technologies in a next generation firewall like the FortiGate. Organizations worldwide use FortiGuard application control and IPS in the FortiGate platform to manage their applications and block network intrusions (every minute of every day FortiGuard blocks ~470,000 intrusion attempts). FortiGates running application control and IPS are tested for effectiveness in industry comparison tests by NSS Labs and consistently receive Recommended ratings.

Web Filtering

Every minute of every day FortiGuard Labs processes approximately 43M URL categorization requests and blocks 160k malicious websites. The Web Filtering service rates over 250M websites and delivers nearly 1.5M new URL ratings every week. FortiGuard is the only VBWeb certified web filtering solution - blocking 97.7% of direct malware downloads in 2016 tests.

AntiVirus and Mobile Security

Every minute of every day FortiGuard Labs neutralizes approximately 95,000 malware programs targeting traditional, mobile and IoT platforms. Patented technologies enable FortiGuard antivirus to identify thousands of current and future malware variants with a single signature – optimizing both security effectiveness and performance. Fortinet consistently receives superior effectiveness results in industry testing with Virus Bulletin and AV Comparatives

AntiSpam

Every minute of every day FortiGuard Labs blocks approximately 21,000 spam emails and each week the Labs deliver approximately 46M new and updated spam rules. Email is the #1 vector for the start of an advanced attack on an organization so highly effective antispam is a key part of a security strategy.

Advanced Threat Protection (FortiSandbox)

Thousands of organizations around the world leverage FortiSandbox to identify advanced threats. FortiSandbox consistently receives a Recommended rating for breach detection systems from NSS Labs in industry tests and in 2015 NSS Labs tests achieved a 97%+ breach detection rating.

IP Reputation

Every minute of every day FortiGuard Labs blocks approximately 32,000 botnet command & control communication attempts. A key part of the attack kill chain on an organization is when the threat communicates with a command & control server – either to download additional threats or to exfiltrate stolen data. IP and Domain address reputation blocks this communication, neutralizing threats.

Appendix A

Devices

per-cary-fw01